AES Raptor Ultra CNC İşleme
Threat & Risk + Risk Matrix

Kavramsal Çerçeve ve Puanlama Metodolojisi

(AB) 2023/1230 Makine Tüzüğü Ek III (Madde 1.1.9 *Yozlaşmaya Karşı Koruma* ve Madde 1.2.1 *Kontrol Sistemlerinin Güvenliği*) ile IEC 62443-3-2 kapsamında yürütülen siber-fiziksel risk değerlendirmesinde bir tehdit senaryosu beş ardışık halkadan oluşur:

Kim (Tehdit Aktörü) −→ **Hangi Kapı (Conduit)** −→ **Ne Yapar (Siber Eylem)** −→ **Zincir (Sistem İçi Etki)** −

Altın Kural: Saldırı zinciri yalnızca "*CAD/CAM kesim dosyaları veya üretim verisi çalındı*" noktasında bitiyorsa bu bir bilgi güvenliği (IT) bulgusudur; makine emniyeti bulgusu sayılması için siber müdahalenin **hattaki operatöre fiziksel olarak ne zarar vereceği** ortaya konulmalıdır.

Risk Skoru Hesaplaması (Skor = $L \times S \times E$**):**

- L **(Likelihood / Olasılık, 1–3):** Tehdidin gerçekleşme sıklığı (1: Düşük/Nadir, 2: Orta/Olası, 3: Yüksek/Sık).
- S **(Severity / Fiziksel Şiddet, 1–3):** İnsana verdiği fiziksel zarar (1: Hafif/İlk yardım gerektiren, 2: Orta/Geri döndürülebilir yaralanma, 3: Ağır/Kalıcı uzuv kaybı veya ölüm).
- E **(Exploitability / Sömürülebilirlik, 1–3):** Saldırının teknik kolaylığı ve erişim açıklığı (1: Zor/Yüksek uzmanlık ve fiziksel erişim şart, 2: Orta/Standart araçlarla yerel ağdan sömürülebilir, 3: Kolay/Kimlik doğrulamasız açık port veya günlük USB/dosya paylaşımı).
- **Öncelik Eşikleri: Kritik:** 18–27 • **Yüksek:** 9–17 • **Orta:** 4–8 • **Düşük:** 1–3. *(Not:* $S = 3$ *ise toplam skor düşük çıksa dahi senaryo önceliklendirilir ve görünür kılınır.)*

Görev: Üç Siber-Fiziksel Tehdit Senaryosu ve Risk Matrisi Tablosu

Senaryo (Kim → Kapı → Ne Yapar → Zincir → Fiziksel Sonuç)	L	S	E	Skor	Öncelik
Senaryo 1 (Portal Köprü Ezilme ve Işık Perdesi Bypass Senaryosu): [Kim] Fabrika IT ağına sızan dış saldırgan / zararlı yazılım → **[Kapı]** Mühendislik İstasyonu (NC Hops/Alphacam) ile OT Hücre Kontrol arasındaki **Conduit 4** (Ethernet dosya paylaşımı) veya **USB portu** → **[Ne Yapar]** RBAC ve ağ izolasyonu eksikliğini kullanarak .DXF/.STEP kesim dosyası transferi üzerinden AES PLC ve OSAI/Syntec belleğine yetkisiz *yazma (write)* komutu gönderir; 100 m/dk hız sınırını ve öndeki dikey ışık perdesi / lazer tarayıcı *bypass* bitlerini değiştirir → **[Zincir]** Operatör ön tablada plaka alırken ışık perdesi kesilmesine rağmen Panasonic servo sürücülere duruş sinyali gitmez; 800–1200 kg kütleli portal köprü 100 m/dk (1.67 m/sn) hızla EN ISO 13855 güvenlik mesafesini (S_{min} =500–621 mm) aşarak operatör alanına dalar → **[Fiziksel Sonuç]** Operatörün ağır portal köprü ile şasi arasında sıkışarak **ezilmesi ve ölümcül yaralanması**.	3	3	3	**27**	**KRİTİK (1. Öncelik)**

Senaryo 2 (DoS + Vakum/Pnömatik Spoofing ile Parça Fırlaması): **[Kim]** Fabrika yerel ağına veya kablosuz spektruma erişen kötü niyetli aktör → **[Kapı] Conduit 4 (OT Hücre Ağı)** ve *Handterminal Pro+* kablosuz haberleşme kanalı → **[Ne Yapar]** CNC kontrol ünitesinin ağ arayüzüne yoğun paket basarak Hizmet Reddi (**DoS / Buffer Overflow**) saldırısı yapar ve eşzamanlı olarak AES PLC'deki 5 Bar pnömatik basınç şalteri ile *Vacuboost* vakum bölgesi geri bildirimlerini yanıltır (*spoofing*) → **[Zincir]** 21 inç HMI ekranı kilitlenir; kesim sırasında Becker vakum pompalarının (2×250 m^3/sa) tuttuğu alüminyum matris tabladaki vakum valfleri kapanır veya basınç 5 Bar altına düşer, ancak kilitlenen kontrolcü Kategori 1 duruşu başlatamaz ve 24.000 RPM (14 kW) HSD iş mili kesime devam eder → **[Fiziksel Sonuç]** Vakum tutuşunu kaybeden ağır MDF/alüminyum plakanın yüksek kesme kuvvetiyle savrularak (**Ejection Hazard**) operatöre çarpması ve **ağır/ölümcül kafa-gövde travması** yaratması.	2	3	2	**12**	**YÜKSEK (2. Öncelik)**
Senaryo 3 (İmzasız Bellenim ile 24.000 RPM İş Mili Pens Açılması): **[Kim]** Uzak bakım kanalını veya servis bilgisayarını ele geçiren hedefli saldırgan → **[Kapı] Conduit 3 (DMZ Uzak Servis / Bakım Kanalı)** → **[Ne Yapar] Secure Boot** (kriptografik imza doğrulaması) bulunmayan OSAI/Syntec kontrolcüye veya PLC katmanına modifiye edilmiş bellenim (*firmware*) yükleyerek EN ISO 19085-3:2021 Madde 5.3.2 kapsamındaki **İş Mili Kilitleme (0 RPM Spindle Interlock)** şartını devre dışı bırakır → **[Zincir]** HSD iş mili 24.000 RPM hızla dönerken ve ≤ 10 sn'lik durma süresi (*run-down time*) beklenmeden pnömatik HSK-F63 takım tutucu pensine "*Takım Bırak (Tool Unclamp)*" sinyali gönderilir → **[Fiziksel Sonuç]** 24.000 RPM'de dönen ağır kesici takımın ve HSK-F63 tutucunun şarapnel gibi fırlayarak muhafazayı delmesi ve operatöre saplanarak **ölümcül yaralanmaya** yol açması.	1	3	2	**6**	**ORTA [Skor: 6] → S=3 KURALIYLA ÖNCELİKLİ!**

Tablo 1: AES Raptor Ultra Siber-Fiziksel Risk Kayıt Defteri (Risk Register — EP 04)

Senaryoların Teknik Analizi ve Değerlendirme Soruları

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

Tek Cümlelik Özet Cevap:
Senaryo 1 (Skor: 27 — Kritik) en yüksek öncelikli senaryodur; çünkü günlük üretimde sürekli açık olan CAD/CAM dosya paylaşım kanalı (Conduit 4) veya USB girişi üzerinden en kolay sömürülebilen ($E=3$) ve en yüksek gerçekleşme olasılığına sahip ($L=3$) saldırı vektörünün, doğrudan 100 m/dk hızındaki 1000 kg'lık portal köprünün emniyet bariyerlerini körelterek operatörü ezmesine ($S=3$) yol açtığı en yakın tehlikedir.
Mühendislik Detayı ve Regülasyon Karşılığı:
AES Raptor Ultra, doğası gereği her vardiyada Mühendislik İstasyonu'ndan (*NC Hops, Alphacam, Cabinet Vision*) yeni kesim listeleri (.DXF, .STL, .STEP) ve ERP/MES barkod verileri alan bir makinedir. Eğer makine mimarisinde Normal PLC / CNC katmanı ile Safety PLC katmanı düz bir ağda (*flat network*) birleştirilmişse, IT ağından sızan bir zararlı yazılım hiçbir kriptografik engelle karşılaşmadan emniyet parametrelerini ezebilir. (AB) 2023/1230 Makine Tüzüğü **Ek III Madde 1.1.9 (Yozlaşmaya Karşı Koruma)** uyarınca bu riski sıfırlamak için:

- Emniyet ışık perdeleri, lazer alan tarayıcı ve basınç tamponları doğrudan izole **Bölge 5 (OT Safety Zone — SL-T 4)** içindeki çift kanallı Safety PLC'ye bağlanmalı ve Panasonic servo sürücülerin donanımsal **STO (Safe Torque Off)** girişlerini ağdan bağımsız olarak kesmelidir.

- Bölge 4'ten Bölge 5'e geçen **Conduit 5** kesinlikle tek yönlü (*salt okunur teşhis*) olmalı; ağ üzerinden hiçbir hız limiti veya ışık perdesi *bypass* biti yazılamamalıdır.

2. $S=3$ olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

Evet, Senaryo 3 ($L=1, S=3, E=2 \rightarrow$ **Skor** $=6$**) bu duruma tam bir örnektir.**
Matematiksel çarpım sonucunda skoru **6 (Orta Risk: 4–8 aralığı)** çıkmıştır; çünkü saldırganın özel olarak OSAI/Syntec veya AES PLC bellenim (firmware) yapısını tersine mühendislikle çözmesi ve bakım kanalından enjekte etmesi yüksek uzmanlık gerektirir ve olasılığı düşüktür ($L=1$). Ancak bu saldırı gerçekleştiğinde, 24.000 RPM hızla dönen HSK-F63 takım tutucunun pensini açarak kesici takımı yüksek kinetik enerjili bir mermi gibi operatöre fırlatmakta ve **ölümcül sonuç (**$S=3$**)** doğurmaktadır.

Risk Kayıt Defterinde (Risk Register) Görünür Kılma ve Yönetme Yöntemi:

1. **"**$S=3$ **Escalation (Şiddet Bayrağı)" Kuralının Uygulanması:** Risk matrisinde yalnızca toplam skora göre sıralama yapıldığında Skor=6 olan bir senaryo, Skor=8 ($L=2, S=2, E=2$) veya Skor=9 ($L=3, S=1, E=3$ — sadece üretim duruşu yaratan) senaryoların altında kaybolma tehlikesi taşır. Bunu önlemek için Risk Register tablosuna otomatik bir **"Kırmızı Bayrak /** $S=3$ **Öncelik Kuralı"** eklenir ve $S=3$ içeren tüm satırlar toplam skoruna bakılmaksızın **"Yüksek Öncelikli Emniyet Kararı Gerektiren Riskler"** grubuna yükseltilir.
2. **Donanımsal ve Kriptografik Karşı Önlem (Mitigation):**
   - **Donanımsal İnterlock (EN ISO 19085-3:2021 Madde 5.3.2):** İş mili sıfır hız (RPM $=0$) denetimi yalnızca yazılımsal bir PLC bitine bırakılmaz; HSD iş mili enkoder/sensöründen gelen duruş sinyali doğrudan PL d / Kategori 3 emniyet rölesi üzerinden pnömatik pens valfini fiziksel olarak kilitler. Böylece PLC bellenimi tamamen ele geçirilse dahi iş mili dönerken pens fiziksel olarak açılamaz.
   - **Secure Boot ve 5 Yıllık Tracing Log ((AB) 2023/1230 Ek III Madde 1.2.1):** CNC ve PLC bellenim yüklemelerinde üretici (AES Group) dijital imzası zorunlu kılınır (*Secure Boot*); imzasız bellenimler donanım tarafından reddedilir ve her güncelleme girişimi 5 yıllık izleme kaydına (*Tracing Log*) işlenir.

Kaynakça

1. **AES Group Raptor Ultra Teknik Analiz Raporu**: CE Uygunluk Değerlendirmesi İçin Tersine Mühendislik Tabanlı Kör Analiz ve Laboratuvar Doğrulama Raporu (3. ve 4. Laboratuvar Uygulamaları: Fonksiyonel Emniyet ve Siber-Fiziksel Güvenlik Denetimi).
2. **Yeni Makine Tüzüğü**: Avrupa Birliği (AB) 2023/1230 Makine Tüzüğü, Ek III Madde 1.1.9 (Yozlaşmaya Karşı Koruma) ve Madde 1.2.1 (Kontrol Sistemlerinin Güvenliği ve Güvenilirliği).
3. **Siber Dayanıklılık Yasası (CRA)**: Avrupa Birliği (AB) 2024/2847 Yönetmeliği, Madde 14 (Zafiyet ve Ciddi Olay Bildirim Yükümlülükleri) ve Ek I (Temel Siber Güvenlik Gereklilikleri).
4. **Endüstriyel Siber Güvenlik ve Risk Standartları**: IEC 62443-3-2 (Endüstriyel Otomasyon ve Kontrol Sistemleri İçin Güvenlik Risk Değerlendirmesi) ve EN ISO 12100:2010 (Makinelerde Güvenlik - Tasarım İçin Genel Prensipler - Risk Değerlendirmesi ve Risk Azaltma).

5. **Makine Emniyeti Standartları**: EN ISO 19085-3:2021 (NC/CNC delik ve freze makineleri güvenliği - Madde 5.3.2 İş mili kilitleme), EN ISO 13849-1 (SRP/CS Performans Seviyeleri) ve EN ISO 13855 (Koruyucuların konumlandırılması ve güvenlik mesafesi hesabı).